🎯 Hoje Vais Ser um Hacker

Workshop de Segurança de Palavras-Passe

Filipe Carneiro

📋 Agenda

1. Palavras-pass usadas
2. Como funcionam as palavras-passe?
3. Como pensa um atacante?
4. Tipos de ataque a palavras-passe
5. Mãos à obra — labs práticos
6. Como se defender
7. Desafio final — CrackStation

🎯 Palavras-pass usadas

Qual é o tipo de palavra-passe que usas?

Responde no Mentimeter

menti.com

Código: `1155 3356`

📊 Palavras-Passe em 2026 em Portugal

Ranking	Palavra-Passe	Tempo para crackar
#1	`123456`	< 1 segundo
#2	`12345678`	< 1 segundo
#3	`password`	< 1 segundo
#4	`qwerty123`	< 1 segundo
#5	`benfica`	< 1 segundo

81% das falhas de segurança envolvem palavras-passe fracas ou roubadas.

🔐 Como Funcionam as Palavras-Passe?

🔐 Como Funcionam as Palavras-Passe?

A tua palavra-passe **nunca** é guardada em claro.

Quando crias uma conta, a tua palavra-passe é **transformada** num hash antes de ser guardada.

> Os sites **nunca guardam a tua palavra-passe** — guardam o hash.

🔑 O que é um Hash?

É uma função matemática unidirecional (tipo "impressão digital").

1. Recebe qualquer texto como entrada (a tua palavra-passe)
2. Devolve sempre uma sequência de caracteres de tamanho fixo (hash)
3. É **irreversível** — não se consegue recuperar a palavra-passe original a partir do hash

```
"password123"   →  SHA-256  →  ef92b778bafe...  (sempre igual)
"password124"   →  SHA-256  →  33631376724e...  (completamente diferente!)
```

> *"Para te protegeres, tens de pensar como o atacante."*

Objetivo: Perceber como funcionam os ataques a palavras-passe para nos defendermos melhor

🧠 Como Pensa um Atacante?

Um hacker não adivinha — **segue um processo**:

```
1. Reconhecimento    →  O que sei sobre o alvo?
2. Recolha de dados  →  Nomes, datas, hobbies, empresa...
3. Geração de listas →  Wordlists personalizadas
4. Ataque            →  Automatizado e persistente
5. Acesso            →  Conta comprometida
```

> A maior vulnerabilidade não é técnica — **é humana**

🗂️ Tipos de Ataque — Visão Geral

ATAQUES A PASSWORDS		
Dicionário	Força Bruta	Rainbow Table
Credential Stuffing	Phishing/Social	

Vamos ver cada um em detalhe...

📖 1 - Ataque de Dicionário

O que é? Tentar palavras de uma lista pré-definida

```
# Lista de palavras comuns → testar uma a uma
wordlist.txt:
  password
  qwerty123
  sporting
  12345678
  ...
```

Por que funciona?

- As pessoas usam palavras reais e previsíveis
- Listas como `rockyou.txt` têm **14 milhões** de palavras-passe reais expostas

💡 Curiosidade — O que é o `rockyou.txt`?

Em **2009**, a empresa RockYou foi hackeada. Os atacantes roubaram **32 milhões de contas** — e as palavras-passe estavam guardadas **em texto simples**, sem qualquer proteção.

Essa lista foi tornada pública e hoje é a wordlist mais usada no mundo:

```
rockyou.txt  →  14 milhões de palavras-passe reais
             →  Inclui: 123456, password, iloveyou, princess...
             →  Usada em praticamente todos os ataques de dicionário
```

> Isto aconteceu porque a RockYou nunca usou hashing — guardava tudo em claro.
> **É por isso que os hashes existem.**

🔨 2 - Ataque de Força Bruta

O que é? Tentar **todas as combinações possíveis**

Comprimento	Caracteres	Combinações	Tempo estimado
4 chars	a-z	456,976	< 1 seg
6 chars	a-z	308 milhões	8 segundos
8 chars	a-z+0-9	218 mil milhões	6 horas
8 chars	a-Z+0-9+símb	6.6 biliões	**semanas**
12 chars	a-Z+0-9+símb	19 sextiliões	**séculos**

Comprimento > Complexidade!

🌈 3 - Rainbow Tables

O que é? Tabelas pré-calculadas de hashes

```
Texto     →   Hash MD5
"pass"    →   1a1dc91c907325c69271ddf0c944bc72
"hello"   →   5d41402abc4b2a76b9719d911017c592
```

Ataque: Guardar milhões de hashes e fazer **lookup inverso**

> Procura o hash da tua palavra-passe e vê se aparece na tabela — se aparecer, já sabem a tua palavra-passe!

🔄 4 - Credential Stuffing

O que é? Usar palavras-passe já **expostas** de outros sites

```
1. Base de dados vazada: LinkedIn 2012
   → 117 milhões de emails + passwords

2. Atacante testa essas credenciais no Gmail,
   Facebook, banco online...

3. Se a pessoa reutilizou a palavra-passe → ACESSO!
```

Estatística assustadora:

> **65%** das pessoas reutilizam palavras-passe em múltiplos sites 💀

🎣 5 - Phishing — O Ataque Mais Eficaz

Alguém sabe algum exemplo de phishing que já tenham visto / experênciado?

🎣 5 - Phishing — O Ataque Mais Eficaz

Não é preciso quebrar a palavra-passe se a pessoa a der

Técnicas comuns:

- Email falso de "banco" ou "Netflix"
- Página de login clonada
- SMS (Smishing)
- Chamada telefónica (Vishing)

```
URL real:    https://www.banco.pt/login
URL falsa:   https://www.banc0.pt/login
                            ^
                      Zero em vez de 'o'!
```

🛠️ MÃOS À OBRA

Parte Prática

🔬 Lab 1 — Verificar um Hash

Podes fazer isso através do terminal:

1 - Gerar hash de uma password:

```
echo -n "password123" | sha256sum
# → ef92b778bafe771e89245b89ecbc08a44a4e166c06659911881f383d4473e94f
```

2 - Verificar se uma password corresponde a um hash:

```
echo -n "password123" | sha256sum | grep ef92b778...
# → Devolve a linha completa do hash, se coincidir!
```

> Não o vamos fazer agora em aula mas podes experimentar em casa.

🔬 Lab 1 — Verificar um Hash

Ou através de sites:

1 - Vai a **codebeautify.org/sha256-hash-generator** e insere a palavra-passe "password123" para ver o hash correspondente.

2 - Experimenta: Qual é a password que gerou este hash?

```
5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8
```

E este?

```
8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92
```

(dica: são muito comuns)

🔬 Lab 1 — Solução

Resposta 1: `password`

Resposta 2: `123456`

🔬 Lab 2 — Have I Been Pwned?

Verifica se as tuas credenciais foram comprometidas:

Acede a: **haveibeenpwned.com** e insere o teu email para ver se apareceu em alguma fuga de dados.

Caso tenhas sido comprometido, o site mostra:

- Que serviços foram afetados (LinkedIn, Adobe, etc.)
- Quantas vezes as tuas credenciais apareceram em fugas de dados
- Data da última fuga.

🔬 Lab 2 — Have I Been Pwned?

Caso o teu email não tenha sido comprometido, o site diz que estás "safe" — mas isso não é garantia de nada!

Tens aqui um exemplo real de um email que apareceu em 62 fugas de dados:

```
filipe@gmail.com
```

Caso o teu email tenha sido comprometido:

1. Muda a palavra-passe **imediatamente** em todas as contas associadas
2. Ativa a autenticação multi-fator (MFA) para segurança extra
3. Verifica se há atividades suspeitas nas contas (logins desconhecidos, emails de reset, etc.)
4. Considera usar um gestor de palavras-passe para evitar reutilização no futuro.

> Vamos falar mais sobre isso já a seguir!

🔬 Lab 3 — Testar a Força da Tua Password

1 - Acede a: **www.security.org/how-secure-is-my-password**

2 - Insere as tuas palavras-passe atuais (Gmail, Instagram, etc.)

3 - O site avalia a força com base em:

- Comprimento
- Complexidade
- Presença em listas de palavras-passe expostas

Dica: Se a tua palavra-passe for "fraca" ou "muito fraca", é hora de mudar!

> Não tenhas medo de escrever a tua palavra-passe real.
> O site é seguro e não a armazena.

🔬 Lab 3 — Testar a Força da Tua Password

Exemplo de avaliação:

```
Password: 12345678
Strength: Very Weak
Time to Crack: Instantly
```

Exemplo de avaliação:

```
Password: cavalobaterialampada
Strength: Strong
Time to Crack: 15 billion years
```

🛡️ COMO TE PROTEGERES

Da teoria à prática de segurança real

> Isto é para ti que o email ficou comprometido no Have I Been Pwned, ou para ti que queres evitar que isso aconteça!

Regra #1 — Comprimento é Rei

Uma palavra-passe longa é melhor que uma palavra-passe "complexa" e curta

```
❌ Fraca:   P@ssw0rd!              (9 caracteres, previsível)
✅ Forte:   cavalobaterialampada   (20 caracteres, fácil de lembrar)
✅ Melhor:  Xk#9mQr$vL2@nWp8fyu5   (20 caracteres aleatórios)
```

Passphrase — 4+ palavras aleatórias juntas:

```
correto-cavalo-bateria-relva
```

→ **Muito mais fácil** de memorizar e **muito mais difícil** de hackear!

Regra #2 — Uma Palavra-Passe por Sítio

Nunca reutilizar palavras-passe!

```
Gmail:      xK9#mQr$vL2@
LinkedIn:   Pn7&wYs!qR4#
Netflix:    Bt3%nZx@jM8$
Banco:      Yw5*kLp#cN1&
```

Sim, é impossível memorizar tudo...

→ **É para isso que servem os gestores de palavras-passe!**

Regra #3 — Usar Gestores de Palavras-Passe

Ferramentas recomendadas:

Ferramenta	Tipo	Destaque
Bitwarden	Open source	Gratuito, auditado
1Password	Comercial	Excelente UX
KeePassXC	Local	Offline, máximo controlo
Proton Pass	Open source	Privacy-first

Como funciona:

- Uma **palavra-passe principal** forte → acesso a todas as outras
- Palavras-passe geradas aleatoriamente para cada sítio
- Sincronização encriptada entre dispositivos

Regra #4 — Usar Autenticação Multi-Fator (MFA)

Mesmo que a palavra-passe seja roubada → acesso bloqueado

```
Algo que SABES     +  Algo que TENS  +  Algo que ÉS
 (palavra-passe)      (telemóvel)      (biometria)
```

Tipos de MFA (do menos ao mais seguro):

1. **SMS / Email** → Melhor que nada, mas fraco
2. **App de autenticação TOTP** (Google Authenticator, Microsoft Authenticator em modo código) → Bom
3. **App com notificação push** (Duo, Microsoft Authenticator) → Muito bom
4. **Chave física** (YubiKey) → Excelente

🚨 Sinais de que Foste Comprometido

Verifica regularmente:

```
# 1. Emails de login que não fizeste
# 2. Atividade estranha nas contas
# 3. Emails de reset que não pediste

# Ferramentas de monitorização:
→ haveibeenpwned.com   (fugas de dados com email)
→ monitor.firefox.com  (alertas automáticos)
→ Google Alerts        (menções do teu nome/email)
```

🏆 Desafio Final — Crackstation

Podes quebrar estes hashes?

Vai a **github.com/filipecarneiro/workshop** e descarrega os 3 ficheiros de hashes:

- `hashes1.txt`
- `hashes2.txt`
- `hashes3.txt`

Acede a **crackstation.net**, cola os hashes e vê o que consegues descobrir.

🏆 Desafio Final — Crackstation

Este desafio é para perceber a importância de usar palavras-passe fortes e únicas!

Aqui vamos ter hashes e veremos quais conseguimos quebrar usando o Crackstation, que é uma ferramenta de ataque de dicionário e força bruta.

Vamos te dar 3 ficheiros com hashes de palavras-passe de diferentes níveis de força:

- `hashes1.txt` → Palavras-passe fracas e comuns
- `hashes2.txt` → Palavras-passe médias com substituições
- `hashes3.txt` → Palavras-passe fortes

🏆 Nível 1 — Palavras-Passe Fracas

Ficheiro: `hashes1.txt`

```
5e884898da28047151d0e56f8dc6292773603d0d6aabbdd62a11ef721d1542d8
8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92
65e84be33532fb784c48129675f9eff3a682b27168c0ea744b2cf58ee02337c5
f97557ce9b1cf089c8ad22a60ea45c2be754ab1ce73c209d5d9c187003e91c87
ef797c8118f02dfb649607dd5d3f8c7623048c9c063d532cc95c5ed7a898a64f
```

> Copia os 5 hashes, cola no Crackstation e clica em **Crack Hashes**.
>
> Deves conseguir todas em **segundos**. 💀

🏆 Nível 2 — Palavras-Passe Médias

Ficheiro: `hashes2.txt`

```
b03ddf3ca2e714a6548e7495e2a03f5e824eaac9837cd7f159c67b90fb4b7342
19f53522e595d4d3cab8e13d15fb552ab20061130e9eff5f124953a6f0ab8c4a
d59b08354c3aa17a537b10c101c1ee566c369ce799df0af822a5e8e3e6777547
725c5c7412b7dbd82469256ea0b8df29c9db4353c9532177043ec58770b08e4c
16726f90cfa7433c42afe969d8b2b393e8818665048d45a7645835149ea48256
```

> Palavras com substituições típicas (a→@, o→0, s→3…).
>
> O Crackstation pode encontrar **algumas** — mas não todas.

🏆 Nível 3 — Palavras-Passe Fortes

Ficheiro: `hashes3.txt`

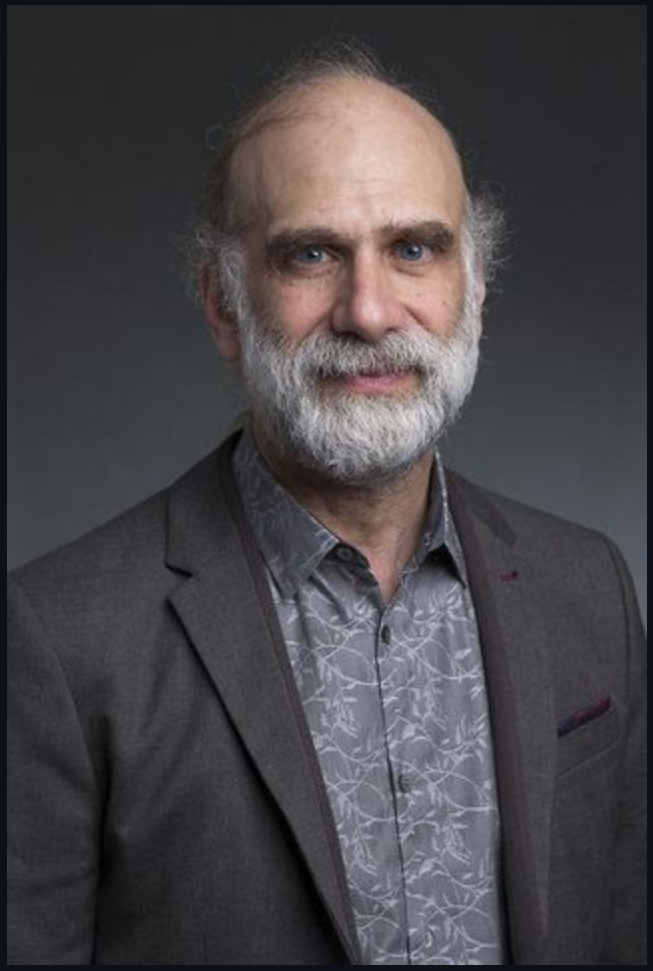
```
2f18b36f3e78fb5230bdf975ee4a074d28fb754acc26b13390a740d681d4678e
a2562e30b8ebb715c4c8081238db1194a9519dc30fa5bfa87a0831f378d4361b
ce06559a6f26cdaf1ba1cf9f4ed48caec487ba25dc9281db8440a90bd58d7752
ee6d6fc4b2afd10387b7ceb46045c6e4de6a11b9d21b3a14f8aa5d94d911bdbf
f09b09e8d0ec9d18ce5d25a94f58ebc588dad2b319f361d393c25c26e966cb43
```

> Palavras-passe longas e aleatórias, geradas por um gestor de palavras-passe.
>
> O Crackstation **não vai encontrar nenhuma**. Nunca. ✅

🔒 Resumo Final

Ataque	Defesa
Dicionário	Palavras-passe longas e aleatórias
Força bruta	Comprimento (12+ chars)
Rainbow table	Hashing moderno (bcrypt/argon2)
Credential stuffing	Palavra-passe única por sítio
Phishing	MFA + verificar URLs

> **"A segurança não é um produto, é um processo."**
> — Bruce Schneier



Dúvidas?

🙌 Obrigado!

Filipe Carneiro